

Segurança de Perímetro

Roteador e ACL

Um roteador (router, em inglês) é um equipamento de rede que efetua o encaminhamento de pacotes de dados entre redes de computadores distintas. Esses pacotes de dados são encaminhados de um roteador para outro até que atinjam o dispositivo de destino, ou sejam descartados. Os roteadores efetuam a leitura dos pacotes IP, podendo analisar o conteúdo de seus cabeçalhos, e então tomar decisões baseando-se nos dados lidos e os protocolos de transmissão implementados em suas configurações.

Os roteadores são conectados em redes distintas, efetuando a conexão entre essas redes, em contraste com um Switch, que efetua a conexão de dispositivos finais, como computadores e notebooks, dentro de uma mesma rede. Os roteadores mantêm domínios de broadcast separados para cada rede que conectam, desta forma isolando-as. Assim, dados direcionados à rede local por um host qualquer permanecem nesta rede local, não sendo encaminhados para as outras redes que estejam conectadas ao roteador. Os roteadores dependem de uma tabela de roteamento para identificar para onde um pacote de dados deve ser encaminhado. As tabelas de roteamento contêm informações sobre o destino, próximo salto, interface, métricas e rotas, que podem ser usadas para guiar o pacote de dados através das linhas de comunicação e em direção ao seu destino.

ACL – Access Control List ou Lista de Controle de Acessos, trata-se de uma lista sequencial de instruções de permissão ou negação que se aplicam a endereços ou protocolos de camada superior, fornecendo uma forma eficiente de controlar o tráfego dentro e fora de uma rede. No geral, as ACLs podem ser configuradas em todos os tipos de roteadores e, são principalmente encontradas nos roteadores de bordas.

A razão mais importante para configurar as ACLs é fornecer segurança para a rede. Porém, podemos ainda utilizar ACLs para outras finalidades em conjunto com a proteção, como por exemplo, a validação do tráfego de pacotes entre as redes LAN e a rede WAN ou a qualidade do serviço (QoS). Lembre-se de que uma ACL é uma lista

sequencial de instruções de permissão ou negação que se aplicam a endereços IP ou protocolos de camada superior. A ACL pode extrair informações contidas no cabeçalho do pacote de dados e, testá-lo em relação às suas regras, tomando a decisão de “permitir” ou “negar” com base no endereço IP/Porta de origem TCP/UDP, no endereço IP/Porta de destino TCP/UDP ou tipo de mensagens ICMP.

Firewall e Gateway de Comunicação

O Firewall é uma solução de segurança baseada em hardware e software que, a partir de um conjunto de regras ou instruções (ACLs), analisa o tráfego de rede para determinar quais operações de transmissão ou recepção de dados podem ser executadas. “Parede de Fogo”, a tradução literal do nome, já deixa claro que o firewall se enquadra em uma espécie de barreira de defesa. Seu objetivo, assim por dizer, consiste basicamente em bloquear tráfego de dados indesejados e liberar acessos bem-vindos.

Para que você possa compreender melhor o funcionamento de um firewall, imagine-o como sendo uma portaria de um prédio: para que você tenha acesso às salas ou apartamentos do prédio, é preciso obedecer a determinadas condições “regras”, como se identificar, ser esperado por um morador do prédio e não portar qualquer tipo de objeto que possa trazer risco à segurança; para sair, não se pode levar nada que pertence aos moradores ou ao prédio sem a devida autorização.

Neste contexto, um firewall pode impedir uma série de ações maliciosas: um malware que utiliza uma determinada porta para se instalar em um host da rede, sem o usuário saber, um aplicativo que envia dados sigilosos para a internet, uma tentativa de acesso à rede a partir de hosts externos não autorizados, entre outros.

Com relação aos gateways de comunicação podem ser encontrados na forma de appliance (hardware) ou software (aplicativo). Porém, podemos ainda sim transformar um computador (PC ou Servidor) em um gateway.

Neste contexto, podemos considerar um gateway como um nó de rede utilizado nas redes de telecomunicações e nas redes de computadores, para interligar duas redes com diferentes protocolos de transmissão. Ou seja, o gateway age como um ponto de entrada e saída para uma rede e, obrigatoriamente, todos os pacotes de dados devem passar ou se comunicar com ele antes de serem roteados pelo roteador. Como

principal vantagem da utilização de um gateway, podemos citar a simplificação da conectividade entre a rede LAN e outra, como por exemplo a WAN ou Internet e a segurança.

No geral, um gateway pode ser considerado uma junção entre um roteador e um modem e, na maioria dos casos sua implementação ocorre na extremidade da rede, ou seja, na borda da rede e, ali ele fica gerenciando todos os pacotes de dados que são direcionados internamente ou externamente na rede.

UTM – Unified Threat Management

O UTM – Unified Threat Management ou Gerenciamento Unificado de Ameaças é um mecanismo de proteção com diversas funções de segurança, tais como: firewall, proxy, sistema de detecção e prevenção a intrusão (IDS/IPS), proteção contra códigos maliciosos e malwares, virtual private network (VPN), controle de conteúdo web, web application firewall (WAF), dentre outros, utilizado na camada de segurança de perímetro, atuando como um “guardião” entre a interligação existente entre a infraestrutura de TI da organização e a Internet.

No geral um UTM é encontrado no formato de appliance, ou seja, em um dispositivo computacional composto por um hardware e um conjunto de softwares específicos e destinados à proteção e segurança cibernética. Entre os diversos modelos de UTM existentes, os mais renomados em termos de eficiência na segurança cibernética são: Sophos XG UTM, Fortigate, Checkpoint e PFSense. Atualmente os UTMs são um mecanismo importante e essencial para a segurança cibernética e, podem ser utilizados em organizações que possuem sua infraestrutura local ou em nuvem.

IDS/IPS – Sistema de Detecção e Prevenção de Intrusão

Conceitualmente, o IDS/IPS – Sistemas de Detecção e Prevenção a Intrusão refere-se a um mecanismo capaz de identificar ou detectar e/ou prevenir a presença de atividades intrusivas. Em um conceito mais amplo, isto engloba todos os processos utilizados na descoberta de utilizações não autorizadas de dispositivos de rede ou de computadores. Ou seja, um IDS/IPS é um mecanismo de proteção de rede que trabalha para detectar e prevenir ameaças através do monitoramento contínuo procurando possíveis tentativas de intrusão realizadas por ameaças. Caso detectado o

IDS/IPS além de comunicar a equipe de segurança cibernética, realiza uma ação pré-determinada para bloquear a tentativa de intrusão.

Além, das funções mencionadas anteriormente o IDS/IPS também pode ser utilizado para identificar problemas relacionados ao não cumprimento das políticas de segurança. Isto porque, auxilia a equipe de segurança da informação ou cibernética na fiscalização de possíveis ações de colaboradores que tentam burlar ou violar as normas e regras impostas nas políticas.

IAM – Sistema de Gerenciamento de Identidade e Acesso

O IAM ou Sistema de Gerenciamento de Identidade e Acesso é um mecanismo de proteção utilizado pelas equipes de segurança da informação e segurança cibernética que permite realizar a gestão de identidades digitais de usuários da organização, bem como controlar o acesso deles a dados, informações, sistemas, serviços e recursos computacionais.

O principal objetivo do IAM é atribuir identidades digitais a cada usuário ou dispositivo na infraestrutura de TI da organização. Uma vez atribuída às identidades digitais, o IAM fornece uma estrutura de gerenciamento que permite às equipes de TI ou de segurança da informação/cibernética manter, modificar e monitorar todos os níveis de acesso e privilégios de cada uma das identidades digitais fornecidas.

Dentre as diversas ações realizadas por um IAM, destacam-se: (a) verificação e autenticação de usuários/dispositivos a sistemas/aplicativos, serviços ou recursos computacionais presentes na organização com base em níveis de acesso previamente definidos; (b) capturar e registrar eventos de autenticação de usuários/dispositivos através de logs de registro; © gerenciar e conceder visibilidade a banco de dados, conforme níveis de acesso previamente concedidos; (d) gerenciar, atribuir e remover níveis de acessos a sistemas, serviços ou recursos computacionais ou da tecnologia da informação da organização; (e) habilitar administradores e sistemas, serviços e recursos de TI a realizar funções de gerenciamento, inclusão, alteração ou remoção de acessos de usuários a sistemas, serviços ou recursos computacionais da organização, incluindo acesso interno ou externo a rede de computadores corporativa.

Com relação aos meios de autenticação, estes podem ser do tipo: (a) SSO ou Single Sign-On – trata-se de uma forma de controle de acesso que permite os usuários se autenticarem a vários sistemas, serviços ou recursos utilizando apenas uma única credencial de acesso “login” que por sua vez irá conter um conjunto de credenciais únicas para cada acesso; (b) Autenticação Multifatorial – trata-se de uma forma de controle de acesso que possui dois ou mais fatores de autenticação que permitem verificar a identidade do usuário com os requisitos para inserir credenciais e fornecer vários fatores de autenticação e acesso. No geral esses fatores são criados de 3 maneiras: 1º algo que o usuário sabe (senha); 2º algo que o usuário possui (token ou código enviado por e-mail ou sms) e 3º algo específico e relacionado ao usuário como, por exemplo, informações biométricas;

Por fim, dentre os benefícios obtidos com o IAM, citamos: acesso seguro a sistemas, aplicativos, serviços e recursos tecnológicos e computacionais; redução de riscos relacionados a roubo de credenciais de acesso; redução de riscos com relação a acessos não autorizados; conformidade com os padrões estabelecidos para criação e manutenção de senhas de acesso, gerenciamento de privilégios de acesso a sistemas, aplicativos, serviços e recursos e, auditoria.

VPN – Virtual Private Network

À medida que uma empresa cresce, ela pode se expandir para várias localidades em sua cidade, país ou em todo o mundo. Para manter as coisas funcionando de maneira eficiente, as pessoas que trabalham nesses locais precisam de uma maneira rápida, segura e confiável de compartilhar informações nas redes de computadores. Funcionários em viagem, como vendedores, precisam de uma maneira igualmente segura e confiável de se conectar à rede de computadores de seus negócios a partir de locais remotos. Mesmo em lazer, as pessoas desejam manter seus computadores em segurança em uma rede desconhecida ou não segura.

Uma tecnologia popular para atingir esses objetivos é uma VPN (rede privada virtual). Uma VPN é uma rede privada que usa uma rede pública (geralmente a Internet) para conectar sites ou usuários remotos. A VPN usa conexões “virtuais” roteadas pela Internet da rede privada da empresa ou de um serviço VPN de terceiros para o site ou pessoa remota. As VPNs ajudam a garantir a segurança - qualquer pessoa que intercepte os dados criptografados não pode lê-los.

O objetivo de uma VPN é fornecer uma conexão privada segura e confiável entre redes de computadores em uma rede pública existente, geralmente a Internet. Entre os benefícios que uma VPN pode oferecer a uma empresa, citamos: (a) conexões estendidas em várias localizações geográficas sem usar uma linha alugada; (b) segurança aprimorada para troca de dados; © flexibilidade para escritórios e funcionários remotos usarem a intranet comercial através de uma conexão de Internet existente, como se estivessem diretamente conectados à rede; (d) economia de tempo e despesas para os funcionários comutarem se trabalharem em locais de trabalho virtuais e, (e) maior produtividade para funcionários remotos.

Uma empresa pode não exigir todos esses benefícios de sua VPN, mas deve exigir os seguintes recursos essenciais de uma VPN: (a) segurança - a VPN deve proteger os dados enquanto viaja na rede pública. Se os invasores tentarem capturar os dados, eles não poderão lê-los ou usá-los; (b) confiabilidade - Os funcionários e escritórios remotos devem poder se conectar à VPN sem problemas a qualquer momento (a menos que o horário seja restrito), e a VPN deve fornecer a mesma qualidade de conexão para cada usuário, mesmo quando estiver lidando com seu número máximo de conexões simultâneas; © escalabilidade - À medida que a empresa cresce, deve poder estender seus serviços VPN para lidar com esse crescimento sem substituir completamente a tecnologia VPN.

As equipes de segurança da informação e segurança cibernética, podem realizar a configuração de uma VPN de dois modos: (a) VPN site to client: permite que usuários individuais estabeleçam conexões seguras com uma rede de computadores remotos. Esses usuários podem acessar os recursos seguros nessa rede como se estivessem diretamente conectados aos servidores da rede. Um exemplo de empresa que precisa de uma VPN de acesso remoto é uma grande empresa com centenas de vendedores em campo (b) VPN site a site: permite que escritórios em vários locais fixos estabeleçam conexões seguras entre si através de uma rede pública como a Internet. A VPN site a site estende a rede da empresa, disponibilizando recursos de computador de um local para funcionários de outros locais. Um exemplo de empresa que precisa de uma VPN site a site é uma empresa em crescimento, com dezenas de filiais em todo o mundo. As VPNs site a site, podem ser do tipo intranet - se uma empresa tiver um ou mais locais remotos nos quais deseja ingressar em uma única rede privada, poderá criar uma VPN na intranet para conectar cada LAN separada a uma única WAN ou do tipo extranet - Quando uma empresa tem um relacionamento

próximo com outra empresa (como um parceiro, fornecedor ou cliente), pode criar uma VPN de extranet que conecta as LANs dessas empresas. Essa VPN de extranet permite que as empresas trabalhem juntas em um ambiente de rede compartilhado e seguro, impedindo o acesso às intranets separadas.

Atualmente as VPNs são consideradas por muitos especialistas de segurança da informação e segurança cibernética, mecanismos confiáveis de proteção para a interligação de infraestruturas de TI distintas e dispostas em regiões físicas diferentes, pois além de prover uma segurança fim a fim de forma segura (criptografada), também fornecem economia.

Conteúdo Bônus

Complemente seu conhecimento assistindo os vídeos disponíveis no YouTube:

- Warriors of the Net - Guerreiros da Internet.
- Invasores – Nenhum Sistema está salvo.

Referência Bibliográfica

CISCO. “**Como funcionam as redes privadas virtuais.**” 13 de outubro de 2008. Disponível em <https://www.cisco.com/c/pt_br/support/docs/security-vpn/ipsec-negotiation-ike-protocols/14106-how-vpn-works.html>.

FONTES, E. **Praticando a segurança da informação**. Brasport, 2008.

FREIRE, Alexandre. **Sistemas de Firewall e Defesa de Perímetros**. Portal Módulo Security, 2004.

Guide to Intrusion Detection and Prevention Systems (IDPS). Disponível em: <<http://csrc.nist.gov/publications/nistpubs/800-94/SP800-94.pdf>>.

HARRIS, Shon. **CISSP All-in-one, 3. ed.:** Mc Graw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LASTRE, H. M. M., ALBAGLI, S. (Org.). **Informação e globalização na era do conhecimento.** Rio de Janeiro: Campus, 1999. 318p.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação.** Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

Microsoft “**TechNect: protocolos de encapsulamento de VPN.**” 2011. (6 de novembro de 2019) Disponível em <[http://technet.microsoft.com/en-us/library/cc771298\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc771298(WS.10).aspx)>.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, W. **Criptografia e Segurança de Redes. 4 ed.** São Paulo: Pearson, 2008.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas. 2.ed.** São Paulo; Elsevier, 2017.

TANENBAUM, Andrew. S. **Redes de Computadores. 4ª ed.** Rio de Janeiro: Editora Campus (Elsevier), 2011.